

Rapport de laboratoire 15

Analyse Dynamique Android : Contournement du SSL Pinning avec Frida et Burp Suite

1. Introduction

Dans le domaine de la sécurité mobile, de nombreuses applications Android utilisent le protocole HTTPS afin de protéger les communications réseau entre l'application et le serveur distant.

Cependant, certaines applications renforcent cette protection grâce au **SSL Pinning**, une technique qui empêche l'interception du trafic par un proxy classique, même lorsqu'un certificat de confiance est installé sur l'appareil.

L'objectif de ce laboratoire est de mettre en place un environnement complet permettant :

- d'intercepter le trafic HTTPS d'une application Android ;
- d'analyser les requêtes réseau ;
- de contourner le mécanisme de SSL Pinning ;
- de comprendre le fonctionnement de l'instrumentation dynamique sur Android.

Principe du SSL Pinning

```
mobexler@Mobexler ~  
└─> python --version  
python 2.7.16  
└─> pip --version  
pip 24.0 from /home/mobexler/.local/lib/python3.7/site-packages/pip (python 3.7)  
└─> frida --version  
16.7.19  
└─> adb connect 192.168.137.107:5555  
* daemon not running; starting now at tcp:5037  
* daemon started successfully  
connected to 192.168.137.107:5555  
└─> adb devices  
List of devices attached  
192.168.137.107:5555    device  
└─> adb shell getprop ro.product.cpu.abi  
x86
```

Le SSL Pinning consiste à intégrer dans l'application une empreinte du certificat du serveur distant.

Lorsqu'une connexion HTTPS est initiée :

- l'application vérifie le certificat reçu ;
- compare ce certificat avec l'empreinte enregistrée ;
- refuse la connexion si les certificats sont différents.

```
mobexler@Mobexler ~
└─> adb push ~/Downloads/frida-server-16.7.19-android-x86 /data/local/tmp/frida-server
/home/mobexler/Downloads/frida-server-16.7...shed. 0.6 MB/s (54758232 bytes in 86.630s)
mobexler@Mobexler ~
└─> adb shell chmod 755 /data/local/tmp/frida-server
mobexler@Mobexler ~
└─> adb shell "/data/local/tmp/frida-server -l 0.0.0.0"
```

Cela empêche l'utilisation d'un proxy TLS classique comme Burp Suite.

Sans SSL Pinning

Application —► Proxy —► Serveur HTTPS
trafic visible

Avec SSL Pinning

Application —► Proxy —► Serveur HTTPS
connexion refusée

```
mobexler@Mobexler ~
└─> frida-ps -Uai
PID  Name                               Identifier
-----
3207  Magisk                               com.topjohnwu.magisk
3323  Superuser                            com.genymotion.superuser
3586  Uncrackable Level 3                 owasp.mstg.uncrackable3
    - Amaze                           com.amaze.filemanager
    - Calendar                         com.android.calendar
    - Camera                           com.android.camera2
    - Clock                            com.android.deskclock
    - Contacts                         com.android.contacts
    - Custom Locale                    com.android.customlocale2
    - Development Settings             com.android.development_settings
    - Email                            com.android.email
    - Files                            com.android.documentsui
    - Gallery                          com.android.gallery3d
    - Messaging                        com.android.messaging
    - Phone                            com.android.dialer
    - Search                           com.android.quicksearchbox
    - SecureStorageInspector           com.secure.storageinspector
    - Settings                         com.android.settings
    - WebView Shell                    org.chromium.webview_shell

mobexler@Mobexler ~
└─> adb forward tcp:27042 tcp:27042
adb forward tcp:27043 tcp:27043
mobexler@Mobexler ~
```

. Concepts étudiés

Concept	Description
SSL Pinning	Validation stricte du certificat serveur

Concept	Description
Frida	Framework d'instrumentation dynamique
frida-server	Agent exécuté sur Android
Burp Suite	Proxy d'analyse réseau
Certificat CA	Certificat de confiance pour Burp
Hook	Remplacement dynamique d'une méthode Java
HostnameVerifier	Vérification du nom d'hôte TLS
TrustManager	Validation de la chaîne de certificats

. Outils utilisés

Outil	Version	Rôle
Frida	16.7.19	Instrumentation dynamique
Burp Suite	Community Edition	Interception HTTPS
Android Debug Bridge	—	Communication Android
Genymotion	—	Émulateur Android
Mobexler	—	Machine virtuelle

. Déroulement du laboratoire

Étape 1 — Installation de Frida

Installation sur la machine principale :

```
pip install frida frida-tools
```

Vérification :

```
frida --version
```

Téléchargement du binaire frida-server correspondant à la même version.

Étape 2 — Déploiement de frida-server

Copie sur l'émulateur :

```
adb push frida-server /data/local/tmp/
```

Ajout des permissions :

```
adb shell chmod 755 /data/local/tmp/frida-server
```

Exécution :

```
adb shell /data/local/tmp/frida-server &
```

Validation :

```
frida-ps -U
```

Étape 3 — Configuration de Burp Suite

The screenshot shows the Burp Suite Settings window. The left sidebar has tabs for 'All', 'User', and 'Project'. Under 'Tools', 'Proxy' is selected. The main panel shows 'Proxy listeners' and 'Request interception rules'.

Proxy listeners

Burp Proxy uses listeners to receive incoming HTTP requests from your browser. You will need to configure your browser to use one of the listeners.

	Running	Interface	Invisible	Redirect	Certificate	TLS Protocols
Add	☐					
Edit	☒	*:8080			Per-host	Default
Remove	☐					

Each installation of Burp generates its own CA certificate that Proxy listeners can use when negotiating TLS connections. You can import or export a certificate from one installation of Burp to another installation of Burp.

[Import / export CA certificate](#) [Regenerate CA certificate](#)

Request interception rules

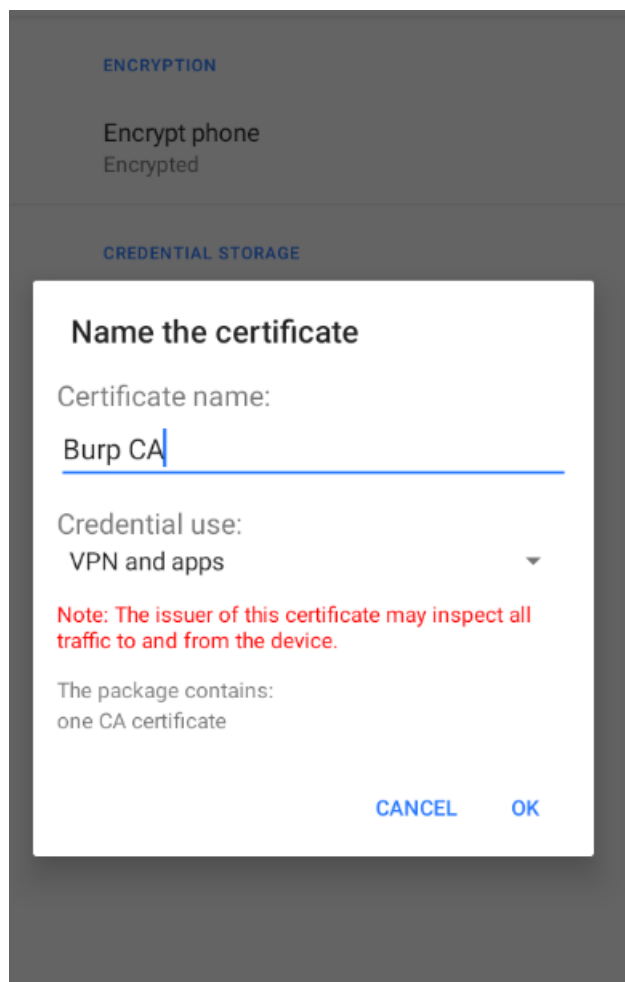
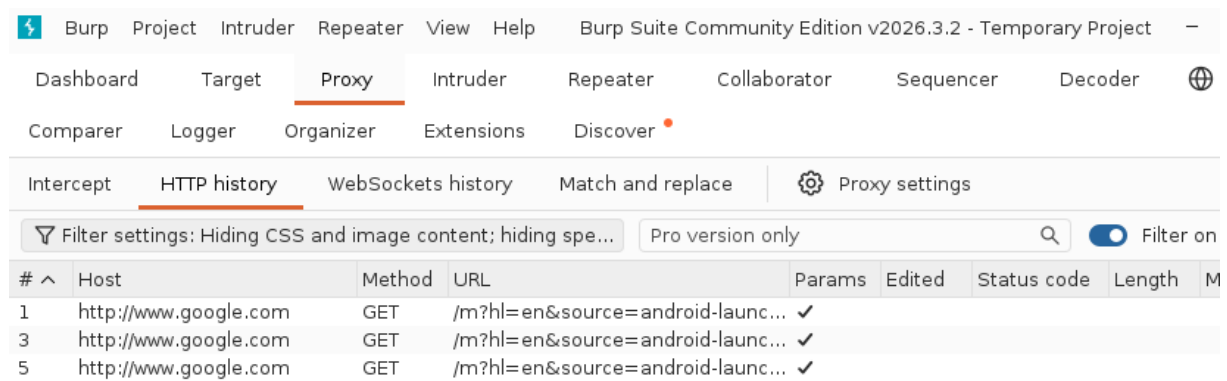
Use these settings to control which requests are stalled for viewing and editing in the Intercept tab.

☒ Intercept requests based on the following rules: *Master interception is turned off*

	Enabled	Operator	Match type	Relationship	Condition
Add	☐				
Edit	☒				
Remove	☐	Or	File extension	Does not match	(^gif\$ ^jpg\$ ^png\$ ^css\$ ^js\$ ^...
Up	☐	Or	Request	Contains parameters	
Down	☐	And	HTTP method	Does not match	(get post)
	☐		URL	Is in target scope	

☐ Automatically fix missing or superfluous new lines at end of request

☒ Automatically update Content-Length header when the request is edited



Configuration du proxy :

- adresse : **0.0.0.0**
- port : **8080**

Export du certificat CA Burp.

Installation du certificat dans Genymotion :

- Settings
- Security
- Install certificate
- Import CA Burp

Configuration du proxy Wi-Fi :

- proxy manuel
- IP machine virtuelle
- port 8080

```
modexler@modexler ~  
└─$ frida -U -f com.android.quicksearchbox -l ~/sslpin_bypass.js  
  
┌───┐  Frida 16.7.19 - A world-class dynamic instrumentation toolkit  
├───┤  
│   │  Commands:  
│   │  help      -> Displays the help system  
│   │  object?   -> Display information about 'object'  
│   │  exit/quit -> Exit  
│   │  
│   │  More info at https://frida.re/docs/home/  
│   │  
│   │  Connected to Phone (id=192.168.137.108:5555)  
└───┘  
Spawned `com.android.quicksearchbox`. Resuming main thread!  
[Phone::com.android.quicksearchbox ]-> [+] Bypass SSL Pinning - Script loaded  
[+] HttpURLConnection hook installed  
[+] SSL Pinning bypass ready  
|
```

Étape 4 — Script Frida

Script utilisé :

```
Java.perform(function() {
```

```
    console.log("[+] SSL Pinning bypass loaded");
```

```
    try {
```

```
        var HttpURLConnection =
```

```
            Java.use("javax.net.ssl.HttpURLConnection");
```

```
        HttpURLConnection
```

```
            .setDefaultHostnameVerifier
```

```

        .implementation = function(verifier) {

            console.log("HostnameVerifier bypass");
            return;
        };

    } catch(e) {}

    try {

        var TrustManagerImpl =
            Java.use(
                "com.android.org.conscrypt.TrustManagerImpl"
            );

        TrustManagerImpl.checkTrusted
            .overload(
                '[Ljava.security.cert.X509Certificate;',
                'java.lang.String',
                'java.lang.String'
            ).implementation = function() {

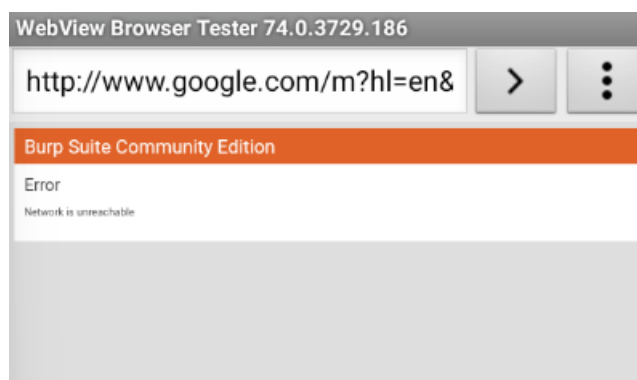
                console.log("TrustManager bypass");
                return;
            };

    } catch(e) {}

});

```

Étape 5 — Injection dans l'application



Commande :

```
frida -U \  
-f com.android.quicksearchbox \  
-l sslpin_bypass.js
```

Résultat :

- chargement du script
- hooks Java actifs
- application lancée normalement

Étape 6 — Analyse du trafic

Une recherche a été effectuée depuis :

com.android.quicksearchbox

Observation dans Burp Suite :

- requêtes HTTPS interceptées ;
- entêtes visibles ;
- contenu déchiffré ;
- historique HTTP enregistré.